A N D R O I D S E C

Security Assessment Report

jakhar.aseem.diva

jakhar.aseem.diva

RISK: CRITICAL

Target rule	COMPONENT_ACTIVITY
Title	Exported activity
Severity / Confidence	Medium / High
MASVS	MASVS-PLATFORM-1
Device	VirtualBox · Android 9
Serial	10.0.2.5:5555
Report ID	20261111_233236
Generated	2026-11-11 23:33 UTC

CONFIDENTIAL — Authorized testing only

Table of Contents

1. Executive Summary
2. Scope & Authorization
3. Environment & Topology
4. Methodology
5. Finding Detail
6. Exploitation / Verification Steps
7. Evidence
8. Remediation
9. Conclusion
10. Appendix A — Executed commands & raw output
11. Appendix B — Captured evidence

Assessment Report

Executive Summary

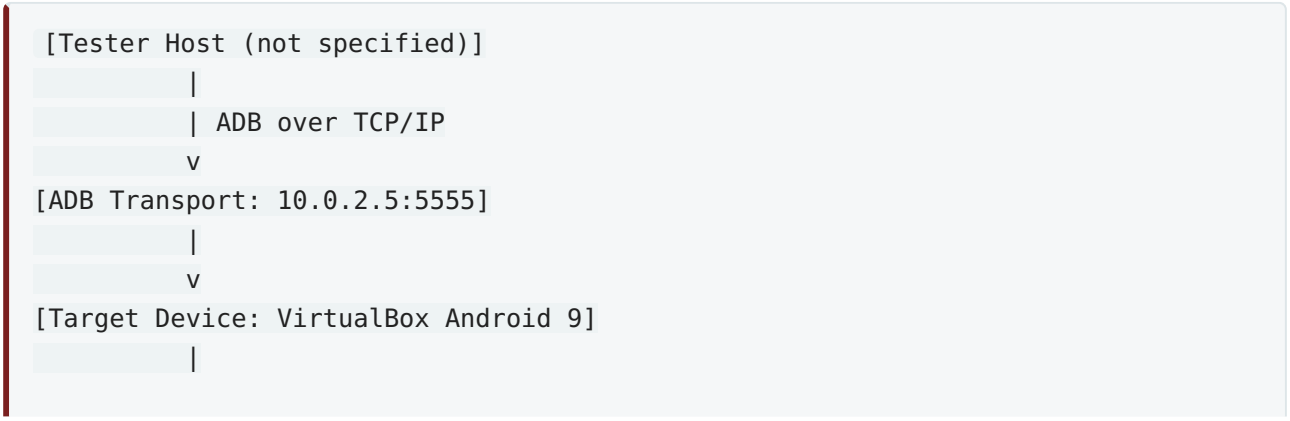
Overall risk for `jakhar.aseem.diva` v1.0 was scored **CRITICAL** (68/100), with finding counts: Critical 0, High 2, Medium 10, Low 0, Info 1. This report confirms one exported activity finding, `COMPONENT_ACTIVITY`, on `jakhar.aseem.diva.APICreds2Activity` with `permission=none`; direct `adb` invocation successfully launched the activity without authorization. Business impact: an unprivileged local actor or malicious app could start this exported activity without permission, potentially accessing API credential functionality or other sensitive UI exposed by the component.

Scope & Authorization

- Target app: `jakhar.aseem.diva` / `jakhar.aseem.diva`
- Version: `1.0`
- Target SDK: `23`
- Size: `1.4 MB`
- SHA-256: `5cefc51fce9bd760b92ab2340477f4dda84b4ae0c5d04a8c9493e4fe34fab7c5`
- Testing window: not specified in the provided data
- Authorization note: Testing was performed as part of a university graduation project; the target APK and device were provided/authorized for assessment.

Environment & Topology

- Tester host: not specified in the provided data
- ADB transport: ADB over TCP/IP to emulator/device serial `10.0.2.5:5555`
- Frida status: no Frida session was used in the provided verification evidence; verification relied on static analysis and `adb`
- Target device: `VirtualBox` Android 9, serial `10.0.2.5:5555`



```
          v
[App: jakhar.aseem.diva v1.0 / targetSdk 23]
```

Methodology

The target APK was statically analyzed to identify exported Android components and manifest permissions. The discovered `COMPONENT_ACTIVITY` issue was then dynamically verified by directly starting the exported activity with `adb` on the target Android device. Screenshots and command output were captured at each step as evidence.

Finding Detail

- Rule ID: `COMPONENT_ACTIVITY`
- Severity: Medium
- Confidence: High
- MASVS: `MASVS-PLATFORM-1`
- Static evidence: `jakhar.aseem.diva.APICreds2Activity (permission=none)`
- Static recommendation: Set `android:exported="false"` or protect with permission.

Exploitation / Verification Steps

1. **Step 1 — Capture baseline UI before exploiting the exported activity** - Command: `screenshot` - Result: `Screenshot saved as screenshot_01.png` - What it proved: A baseline visual state was captured before launching the exported activity.
2. **Step 2 — Directly start the exported APICreds2Activity without any permission using adb** - Command: `adb shell am start -W -n jakhar.aseem.diva/jakhar.aseem.diva.APICreds2Activity` - Result: `Starting: Intent { cmp=jakhar.aseem.diva/.APICreds2Activity } Status: ok Activity: jakhar.aseem.diva/.APICreds2Activity ThisTime: 125 TotalTime: 125 WaitTime: 129 Complete` - What it proved: `APICreds2Activity` is exported and can be launched directly via `adb` without requiring any permission.
3. **Step 3 — Screenshot the resulting APICreds2Activity UI as proof of unauthorized access** - Command: `screenshot` - Result: `Screenshot saved as screenshot_03.png` - What it proved: The `APICreds2Activity` UI was reached and captured, confirming unauthorized access to the exported activity screen.

Evidence

- Screenshot from **Step 1**: Capture baseline UI before exploiting the exported activity — screen captured at step 1.

- Text output from **Step 2**: Command output of `adb shell am start -W -n jakhar.aseem.diva/jakhar.aseem.diva.APICreds2Activity` — proves successful direct launch of the exported activity.
- Screenshot from **Step 3**: Screenshot the resulting `APICreds2Activity` UI as proof of unauthorized access — screen captured at step 3.

Remediation

- Set `android:exported="false"` on `jakhar.aseem.diva.APICreds2Activity` unless the activity must be started by other apps.
- If the activity must be exportable, protect it with a custom permission using `android:permission`, or require authentication/authorization before showing sensitive content.
- Review all other exported activities and components, especially any with `permission=none`.
- Apply least-privilege component exposure across the app.
- Re-test by running the same `adb shell am start` command after remediation to confirm the activity is no longer accessible without permission.

Conclusion

Residual risk: while `jakhar.aseem.diva.APICreds2Activity` remains exported with no permission, any local user or app that can issue an Intent can launch it directly. The dynamic verification confirms the issue is exploitable on the target device. This report details only the supplied finding; the risk count also includes additional High and Medium findings that are not detailed here and remain as residual risk.

Follow-up actions: - Apply the remediation above and re-test the exported activity. - Review and remediate the remaining High and Medium findings reflected in the overall risk count. - Perform a full MASVS-PLATFORM-1 review of all exported components. - Re-run static and dynamic verification after fixes.

Appendix A — Executed Commands & Raw Output

Step 1 — Capture baseline UI before exploiting the exported activity

`screenshot`

```
Screenshot saved as screenshot_01.png
```

Step 2 — Directly start the exported APICreds2Activity without any permission using adb

`adb shell am start -W -n jakhar.aseem.diva/jakhar.aseem.diva.APICreds2Activity`

```
Starting: Intent { cmp=jakhar.aseem.diva/.APICreds2Activity }
Status: ok
Activity: jakhar.aseem.diva/.APICreds2Activity
ThisTime: 125
TotalTime: 125
WaitTime: 129
Complete
```

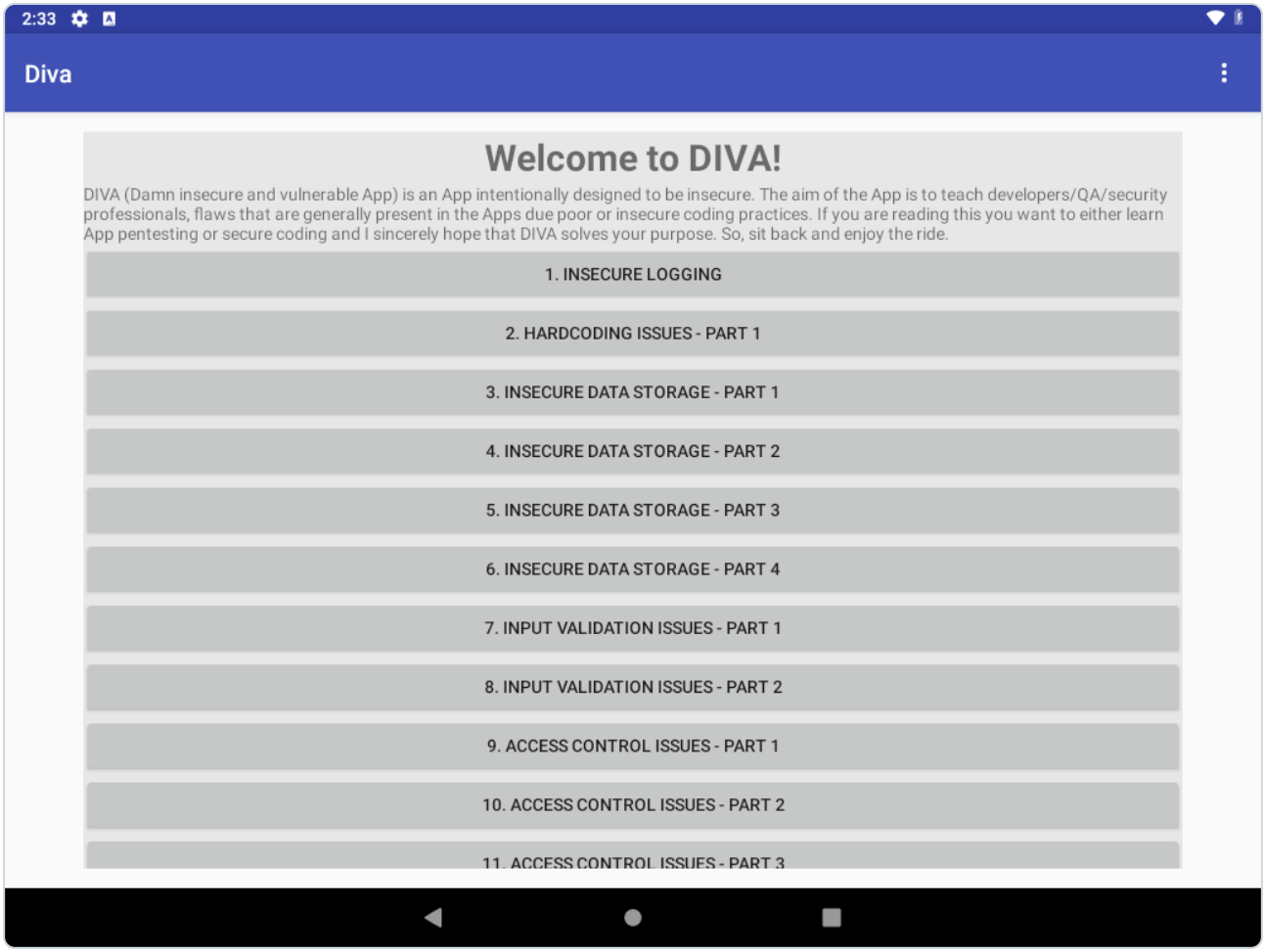
Step 3 — Screenshot the resulting APICreds2Activity UI as proof of unauthorized access

`screenshot`

```
Screenshot saved as screenshot_03.png
```

Appendix B — Captured Evidence

Screenshot — Capture baseline UI before exploiting the exported activity



Command output — Directly start the exported APICreds2Activity without any permission using adb

```
Starting: Intent { cmp=jakhar.aseem.diva/.APICreds2Activity }
Status: ok
Activity: jakhar.aseem.diva/.APICreds2Activity
ThisTime: 125
TotalTime: 125
WaitTime: 129
Complete
```

Screenshot — Screenshot the resulting APICreds2Activity UI as proof of unauthorized access

